

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Zero-day vulnerabilities in Microsoft Exchange
Server**

Date of Publication

September 30, 2022

Last updated date

November 9, 2022

Admiralty Code

A1

TA Number

TA2022213

Summary

Microsoft Exchange Server has two zero-day vulnerabilities. One of them is a Server-Side Request Forgery (SSRF) vulnerability(CVE-2022-41040), while the second is a remote code execution (RCE) vulnerability (CVE-2022-41082)in PowerShell. An authenticated attacker can exploit these vulnerabilities together to gain access to a victim's system by chaining them together.

⚙️ CVE Table

CVE	NAME	PATCH
CVE-2022-41040	Server-Side Request Forgery (SSRF) vulnerability (ProxyNotShell)	✅
CVE-2022-41082	Remote Code Execution (RCE) vulnerability (ProxyNotShell)	✅

⚙️ Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0002</u> Execution	<u>TA0003</u> Persistence	<u>TA0005</u> Defense Evasion
<u>TA0006</u> Credential Access	<u>TA0007</u> Discovery	<u>TA0008</u> Lateral Movement	<u>TA0009</u> Collection
<u>T1586</u> Compromise Accounts	<u>T1586.002</u> Email Accounts	<u>T1059</u> Command and Scripting Interpreter	<u>T1059.003</u> Windows Command Shell

<u>T1505</u> Server Software Component	<u>T1505.003</u> Web Shell	<u>T1070</u> Indicator Removal on Host	<u>T1070.004</u> File Deletion
<u>T1036</u> Masquerading	<u>T1036.005</u> Match Legitimate Name or Location	<u>T1620</u> Reflective Code Loading	<u>T1003</u> OS Credential Dumping
<u>T1003.001</u> LSASS Memory	<u>T1087</u> Account Discovery	<u>T1083</u> File and Directory Discovery	<u>T1057</u> Process Discovery
<u>T1049</u> System Network Connections Discovery	<u>T1570</u> Lateral Tool Transfer	<u>T1560</u> Archive Collected Data	<u>T1560.001</u> Archive via Utility
<u>T1047</u> Windows Management Instrumentation			

Technical Details

#1

The infection chain begins with the attacker sending a malicious HTTP request to port 443 and then exploiting CVE-2022-41040 and CVE-2022-21082.

#2

When the flaws are successfully exploited, attackers could use remote code execution to get access to the victim's systems, allowing them to dump obfuscated web shells to Exchange servers and move laterally throughout the compromised network. Encoding of the web shell in simplified Chinese.

#3

The attacker used Antsword, an active Chinese-based open-source cross-platform website administration tool that supports web shell management. Exploitation requests in IIS logs are structured similarly to ProxyShell Exchange Server vulnerabilities.

#4

A temporary workaround is been provided by [Microsoft](#) and can be applied to avoid exploitation.



Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41040	Microsoft Exchange Server 2013, 2016, and 2019.	cpe:2.3:a:microsoft:microsoft_exchange_server:*:*:*:*:*	CWE-918
CVE-2022-41082	Microsoft Exchange Server 2013, 2016, and 2019.	cpe:2.3:a:microsoft:microsoft_exchange_server:*:*:*:*:*	CWE-94



Indicator of Compromise (IOC)

TYPE	VALUE
FilePath	C:\ProgramFiles\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth C:\inetpub\wwwroot\aspnet_client C:\ProgramFiles\Microsoft\Exchange Server\V15\FrontEnd\HttpProxy\owa\auth C:\Program Files\Common Files\system\ado\msado32.tlb C:\root\DrSDKCaller.exe C:\Users\Public\all.exe C:\Users\Public\dump.dll C:\Users\Public\ad.exe C:\PerfLogs\gpg-error.exe C:\PerfLogs\cm.exe
SHA256	074eb0e75bb2d8f59f1fd571a8c5b76f9c899834893da6f7591b68531 f2b5d82 45c8233236a69a081ee390d4faa253177180b2bd45d8ed08369e074 29ffbe0a9 9ceca98c2b24ee30d64184d9d2470f6f2509ed914dafb87604123057 a14c57c0 29b75f0db3006440651c6342dc3c0672210cfb339141c75e12f6c84d 990931c3 c8c907a67955bcdff07dd11d35f2a23498fb5ffe5c6b5d7f36870cf07da 47bff2 c838e77afe750d713e67ffeb4ec1b82ee9066cbe21f11181fd34429f70 831ec1 65a002fe655dc1751add167cf00adf284c080ab2e97cd386881518d3 a31d27f5 b5038f1912e7253c7747d2f0fa5310ee8319288f818392298fd920099 26268ca be07bd9310d7a487ca2f49bcdafb9513c0c8f99921fdf79a05eaba25 b52d257 76a2f2644cb372f540e179ca2baa110b71de3370bb560aca65dcddb 7da3701e
FileName	RedirSuiteServiceProxy.aspx Xml.ashx pxh4HG1v.ashx DrSDKCaller.exe all.exe dump.dll ad.exe gpg-error.exe cm.exe msado32.tlb

TYPE	VALUE
IPV4	137[.]184[.]67[.]33 125[.]212[.]220[.]48 5[.]180[.]61[.]17 47[.]242[.]39[.]92 61[.]244[.]94[.]85 86[.]48[.]6[.]69 86[.]48[.]12[.]64 94[.]140[.]8[.]48 94[.]140[.]8[.]113 103[.]9[.]76[.]208 103[.]9[.]76[.]211 104[.]244[.]79[.]6 112[.]118[.]48[.]186 122[.]155[.]174[.]188 125[.]212[.]241[.]134 185[.]220[.]101[.]182 194[.]150[.]167[.]88 212[.]119[.]34[.]11 137[.]184[.]67[.]33
URL	hxxp://206[.]188[.]196[.]77:8080/themes.aspx

🔗 Patch Link

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41040>

<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2022-41082>

🔗 References

<https://msrc-blog.microsoft.com/2022/09/29/customer-guidance-for-reported-zero-day-vulnerabilities-in-microsoft-exchange-server/>

<https://www.microsoft.com/security/blog/2022/09/30/analyzing-attacks-using-the-exchange-vulnerabilities-cve-2022-41040-and-cve-2022-41082/>

<https://gteltsc.vn/blog/warning-new-attack-campaign-utilized-a-new-0day-rce-vulnerability-on-microsoft-exchange-server-12715.html>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

September 30, 2022 • 3:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com